

TAREA NDC04

**Legislación y jurisprudencia en materia de
protección de datos.**

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Legitimación y Transferencias Internacionales	3
Respuestas 1	3
Apartado 2: Gestión de Consentimiento Web	4
Respuestas 2	4
Apartado 3: Cumplimiento Normativo Corporativo	5
Respuestas 3	5
Apartado 4: Inteligencia Artificial y Datos Biométricos	6
Respuestas 4	6

Detalles de la tarea de esta unidad

Caso práctico

La compañía ACME S.A. sigue creciendo. Mantiene sus 300.000 clientes y su sede inteligente en Madrid. Sin embargo, para este año fiscal, la dirección ha lanzado el plan de modernización "ACME 2025" que incluye:

- *La contratación de un CRM en la nube alojado en servidores de California (EE.UU.) para gestionar los datos de todos los clientes.*
- *El lanzamiento de una nueva campaña de marketing digital que requiere rastrear la navegación de los usuarios en su web.*
- *La implementación de un sistema de Inteligencia Artificial para analizar las emociones de los empleados mediante las cámaras de seguridad y mejorar el clima laboral.*

Debido a su tamaño y volumen de negocio, se han detectado posibles irregularidades financieras internas que nadie se atreve a reportar.

Actuando como el nuevo Delegado de Protección de Datos (DPO) de ACME S.A., debes emitir un informe jurídico-técnico respondiendo a los siguientes retos planteados por la dirección.

Apartado 1: Legitimación y Transferencias Internacionales

La dirección quiere migrar la base de datos de clientes al proveedor estadounidense "SiliconData Inc.". El director técnico dice: "Hace dos años esto era un infierno legal, mejor no lo hagamos".

1. Explica a la dirección cuál es la situación actual (post-julio 2023) respecto a las transferencias de datos a EE.UU.
2. ¿Qué verificación específica debes realizar sobre "SiliconData Inc." para que la transferencia sea legal sin necesitar autorizaciones complejas? (referencia al Data Privacy Framework).

Respuestas 1

Basándonos en la información de la unidad y los datos facilitados con la actual normativa, podemos indicar al director técnico lo siguiente:

1. Desde julio de 2023, la situación ha cambiado radicalmente con la aprobación del **Marco de Privacidad de Datos UE-EE.UU. (EU-US Data Privacy Framework)** por parte de la Comisión Europea.

ACTUALIZACIÓN (Vigente desde Julio 2023): La Comisión Europea aprobó el **Marco de Privacidad de Datos UE-EE.UU. (EU-US Data Privacy Framework)**.

- **¿Qué significa?** La UE ha emitido una "decisión de adecuación". Esto significa que se vuelve a considerar que EE.UU. ofrece un nivel de protección equiparable al europeo.
- **¿Cómo funciona?** Las empresas estadounidenses pueden certificarse en este marco. Si la empresa proveedora está en la lista certificada, los datos pueden fluir libremente desde Europa sin necesidad de autorizaciones especiales.
- **Impacto:** Facilita enormemente el uso de proveedores tecnológicos americanos para las empresas europeas.

2. Para que la transferencia a "SiliconData Inc." sea legal sin autorizaciones complejas, tenemos que verificar que la empresa esté incluida en la lista de entidades certificadas bajo el nuevo Marco de Privacidad de Datos. Si figura en dicha lista, los datos pueden fluir libremente desde nuestra sede en España hacia sus servidores en California sin autorizaciones especiales.

Apartado 2: Gestión de Consentimiento Web

El equipo de marketing ha diseñado un nuevo banner de cookies para la web. Actualmente se ve así:

Texto: "Usamos cookies para mejorar tu experiencia." Botón 1 (Verde, Grande): [ACEPTAR TODO] Enlace (Pequeño, Gris): "Configurar opciones" (al hacer clic lleva a un menú donde se puede desmarcar manualmente).

1. Analiza la legalidad de este banner según la normativa actual de la AEPD. ¿Es sancionable? ¿Por qué?
2. Dibuja o describe cómo debe ser obligatoriamente la primera capa de información de ese banner para cumplir con la ley (paridad de botones).

Respuestas 2

En base a los conocimientos adquiridos en la unidad podemos indicar lo siguiente:

1. El banner propuesto por marketing es ilegal y sancionable por la Agencia Española de Protección de Datos (AEPD). El motivo principal es que obliga al usuario a realizar más pasos para rechazar las cookies que para aceptarlas, lo cual se considera un **"patrón oscuro"** (diseño engañoso). La normativa actual exige evitar la **"fatiga del consentimiento"** y no poner dificultades adicionales al usuario que no desea ser rastreado

2. Gestión de Cookies: El botón "Rechazar"

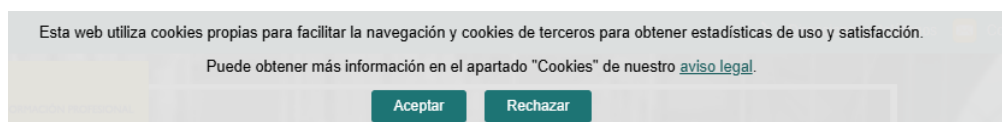
Situación anterior: La normativa permitía banners de cookies donde aparecía un botón de "Aceptar" grande y visible, mientras que la opción de rechazar las cookies se encontraba oculta en una segunda capa (dentro de un menú de "Configuración" o "Más opciones").

ACTUALIZACIÓN (Vigente desde Julio 2023): Siguiendo las directrices del Comité Europeo de Protección de Datos (CEPD), la Agencia Española de Protección de Datos (AEPD) actualizó su guía.

- **La nueva obligación:** El banner de cookies debe presentar la opción de **"Rechazar todas"** (o "Rechazar") en el mismo nivel, con la misma visibilidad y el mismo diseño que la opción de "Aceptar".

2. Para cumplir con la ley, se debe garantizar la paridad de botones. Esto significa que el usuario debe ver, con el mismo nivel de visibilidad, tamaño y diseño, dos opciones claras:

- Un botón de **[ACEPTAR]**.
- Un botón de **[RECHAZAR]**



Ejemplo legal de gestión de cookies

Apartado 3: Cumplimiento Normativo Corporativo

ACME tiene más de 50 empleados y factura millones de euros. Se sospecha de un fraude interno, pero los empleados tienen miedo a represalias si hablan.

1. Según la Ley 2/2023, ¿está obligada ACME a implantar un sistema interno de información (Canal de Denuncias)? Justifica tu respuesta por volumen de empleados.
2. El CEO propone que las denuncias se envíen a su correo personal (ceo@acme.sa) y que el denunciante deba firmar con su nombre y DNI obligatoriamente. ¿Es esto legal? Explica el requisito de anonimato/confidencialidad.

Respuestas 3

1. Sí, **ACME S.A.** estaría obligada por ley a implantar un Sistema Interno de Información según la Ley 2/2023.

La normativa establece que todas las empresas que cuenten con **50 o más trabajadores** deben tener este canal de forma obligatoria y ACME estaría dentro de dicha obligación.

ACTUALIZACIÓN (Ley 2/2023): Se aprobó la Ley reguladora de la protección de las personas que informen sobre infracciones normativas y de lucha contra la corrupción.

- **Obligatoriedad:** Todas las empresas con **50 o más trabajadores** están obligadas a implantar un Sistema Interno de Información (Canal de Denuncias).
- **Relación con la Privacidad:**
 - El canal debe permitir denuncias **anónimas**.
 - El acceso a los datos de la denuncia está restringido exclusivamente a los responsables del sistema (RRHH o Compliance).
 - El Delegado de Protección de Datos (DPD) juega un papel crucial garantizando que no se filtren identidades.

2. La propuesta del CEO es totalmente ilegal por dos razones fundamentales:

- **Anonimato:** La Ley 2/2023 exige que el canal debe permitir denuncias anónimas para proteger al informante de posibles represalias.
- **Confidencialidad y acceso:** El acceso a las denuncias debe estar restringido exclusivamente a los responsables del sistema (normalmente RRHH o Compliance) y al DPO.

El uso de un correo personal del CEO compromete la confidencialidad y la gestión de la denuncia.

Apartado 4: Inteligencia Artificial y Datos Biométricos

Sobre la propuesta de usar las cámaras de seguridad para "analizar emociones de empleados" mediante IA:

1. Identifica qué tipo de dato se estaría tratando (¿es un dato básico o de categoría especial según el art. 9 del RGPD?).
2. Basándote en el Reglamento Europeo de IA, clasifica este sistema. ¿Es un sistema de alto riesgo, de riesgo limitado o una práctica prohibida?

Respuestas 4

1. El análisis de emociones mediante cámaras de seguridad implica el tratamiento de datos de categoría especial (datos biométricos) y por lo tanto, según el artículo 9 del RGPD. Estos datos son especialmente sensibles porque identifican o permiten identificar a una persona de forma única y revelan aspectos íntimos de su personalidad o estado de salud.

4. Novedad Tecnológica: El Reglamento de IA (AI Act)

Aunque la unidad se centra en datos personales, es imprescindible conocer la entrada en vigor del **Reglamento Europeo de Inteligencia Artificial (2024)**.

- **¿Por qué afecta a esta unidad?** La IA utiliza masivamente datos personales para entrenarse.
- **Prohibiciones:** Se prohíben sistemas de IA de "riesgo inaceptable", como aquellos que utilizan datos biométricos para la identificación remota en tiempo real en espacios públicos (salvo excepciones policiales muy graves) o el *scoring* social.

2. Según el Reglamento Europeo de IA (2024), la utilización de sistemas de identificación biométrica o de análisis de categorías sensibles se considera una práctica prohibida.

El Reglamento prohíbe expresamente la inferencia de emociones en el ámbito laboral y educativo, así como los sistemas de scoring social.